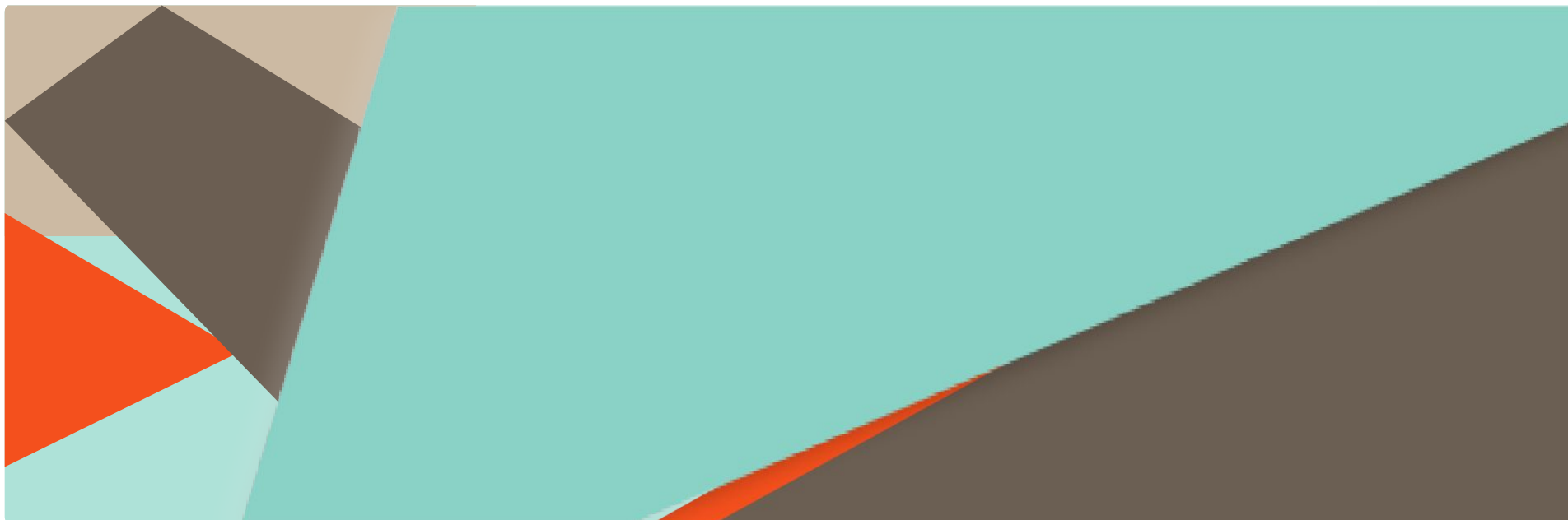




SAN-log_it

Modélisation d'une ESN cybersécurité

Soutenance du 23 juin 2026

Auteur : Benoît Robart

Master 1 Cybersécurité
RNCP 38117

Contextes et contraintes



Message clef : J’assume la nature spéculative du mémoire

Constat

Stage non obligatoire, pas de mission terrain

**SARL SAN-log_it existe (SIRET 987 619 145 00012)
actuellement sans client**

Pas de retour d'expérience client

Réponse apportée

Mémoire prospectif de modélisation d'entreprise

Structure au Jour 0 – activité réelle à lancer

**Validation par preuves de concept :
(site web, simulateur, labo virtuel)**

Ce mémoire n'est pas un rapport de stage. C'est un **business plan technique et stratégique** pour une **ESN en création**, que j'ai construite légalement mais qui n'a pas encore de contrat. Toutes les affirmations techniques sont étayées par des preuves de concept.

Problématique reformulée



« Comment une micro-ESN en phase de création, sans client, sans SLA et sans DSI i peut-elle formaliser une offre de cybersécurité crédible, conforme à NIS2 et économiquement viable pour des PME de 20 à 50 salariés ? »

Annexes et livrables

https://github.com/001418-M1/SAN-log_it-Master-1

Site web déployé sur Hostinger : <https://san-log-it.com/>

Site GitHub de déploiement : https://github.com/001418-M1/SAN-log_it-Website

Sous-questions explorées:

- Quelles prestations ? [catalogue de services](#)
- Quels référentiels ? [ANSSI](#), [CIS](#), [NIST](#)
- Quel modèle économique ? [CAPEX/OPEX](#), [RO](#)
- Quelles preuves de compétence sans mission réelle ? [site web](#), [simulateur](#)

Périmètre du mémoire

Dans le périmètre

- Modélisation d'une offre de services (packages)
- Architecture technique de référence :
(VLAN, pfSense, AD, supervision)
- Conformité réglementaire :
(RGPD, NIS2 – niveau compliance-ready)
- Modèle économique (devis, CAPEX/OPEX).
- Preuve de concept technique : (site web React + simulateur)
- <https://san-log-it.com/> (site en Français & en Anglais)

Hors périmètre (assumé)

- Mission client réelle
- SLA contractuel
- Supervision 24/7 (SOC)
- Retour d'expérience terrain et KPIs
de production

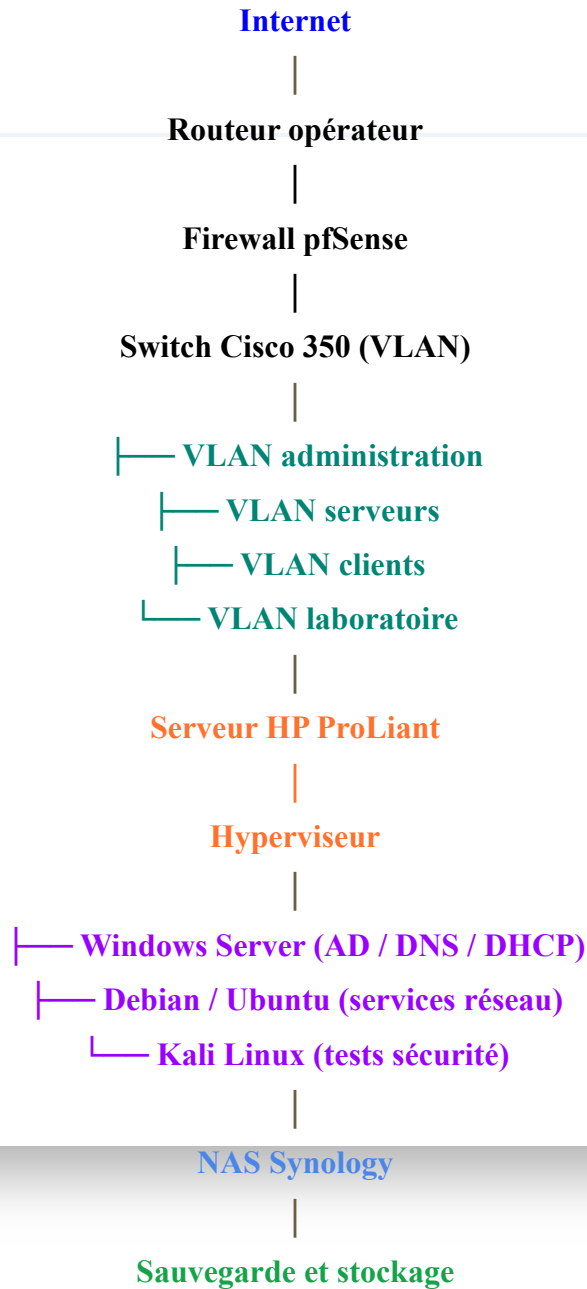
Architecture technique cible



Catégorie	Composant	Technologie	Rôle dans l'architecture
Réseau	Pare-feu / Routeur	pfSense	Filtrage, NAT, routage inter-VLAN, DHCP Relay
	Switch	Cisco CBS350	VLAN, segmentation physique et logique
Système	Serveur	HPE ProLiant DL380	Virtualisation (Windows Server, Debian, Ubuntu, Kali)
	Stockage	Synology NAS	Sauvegardes, versionnement des données
Supervision	Monitoring	Prometheus + Grafana	Collecte métriques, dashboards, alerting
Sécurité	IDS / SIEM	Suricata + Wazuh	Détection intrusion, corrélation, centralisation logs
Cloud	Démo / Web	Hostinger + Docker	Hébergement site + simulateur de devis

Preuve: Schéma détaillé (page 9 du mémoire)

Architecture technique cible



Niveau de maturité : évaluation

Niveau	Critère Principal	Statut SAN-log_it
1	Absence de mesures	Dépassé
2	Mise à jour, antivirus de base	Dépassé
3	Supervision active + segmentation réseau	Atteint (revendiqué)
4	Politique formalisée + audit externe	PSSI à écrire
5	Certification ISO 27001	Non visé à ce stade

Justification Niveau 3:

- Segmentation VLAN + pfSense
- Suricata IDS et Prometheus/Grafana
- Wazuh + Loki (logs centralisés)

Point d'honnêteté :

le niveau nécessite une PSSI formalisée et un audit externe. C'est la prochaine étape, pas encore réalisée dans ce mémoire spéculatif.

Évaluation basée sur le guide ANSSI "Hygiène informatique – Niveau 3 : supervision active + segmentation". Les exigences sont remplies : VLAN/pfSense, Suricata IDS, Wazuh/Loki, Prometheus.

Conformité RGPD et NIS2

Volet RGPD

- Traitements qui sont limités aux :
clients, stagiaires, logs, comptabilité.
- Sous-Traitants : **Exigence de localisation UE**
(Infomaniak, OVHcloud) ou Suisse.
La Suisse n'est pas dans l'UE.
(adéquation reconnue par la Commission UE)
- Mesures techniques : **TLS 1.3 forcé**
 - ❖ Contrôle d'accès SSH/RSA.
 - ❖ Sauvegardes régulières (NAS).
 - ❖ Conformes à l'article 32 du **RGPD**

Volet Directive NIS2

- SAN-log_it n'y est pas soumis directement car :
employés < 50 et CA < 10 M€
- Cependant, posture "**compliance ready**"
car les mesures techniques de l'article 21
(hygiène informatique) sont déjà intégrées
à l'architecture cible.

Argument clef : Nous pouvons intervenir chez les clients soumis à NIS2 car notre architecture de référence respecte déjà les exigences de détection, journalisation et gestion des incidents.

Limite assumée : La procédure de déclaration d'incident (**24h / 72h / 1 mois**) n'a pas pu être testée en conditions réelles de crise.

Analyse EBIOS RM :



Matrice vraisemblance × gravité : Niveau de risque = croisement vraisemblance (lignes) × gravité (colonnes).
Cette grille reproduit exactement les niveaux cotés dans la V0.1 (SO1–SO7) et les rend dérivables

Vraisemblance \ Gravité	G1 — Mineure	G2 — Significative	G3 — Majeure	G4 — Critique
V4 — Quasi-certain	Modéré	Élevé	Critique	Critique
V3 — Vraisemblable	Modéré	Élevé	Élevé	Critique
V2 — Possible	Faible	Modéré	Élevé	Élevé
V1 — Minime	Faible	Faible	Modéré	Élevé

Légende : Faible Modéré Élevé Critique

Application : cotation des scénarios opérationnels (état initial)

Scénario opérationnel	Vraisemblance	Gravité	Niveau de risque
SO1 — Phishing du gérant → vol des secrets → accès clients	V3	G4	Critique
SO2 — Ransomware (service exposé/CVE) → chiffrement NAS + VMs	V3	G4	Critique
SO3 — Accès client non révoqué en fin de mission	V3	G3	Élevé
SO4 — Cloisonnement insuffisant labo Kali ↔ production	V2	G3	Élevé
SO5 — Compromission d'un dépôt de configs/Master	V2	G3	Élevé
SO6 — Perte / vol du portable d'administration	V2	G3	Élevé
SO7 — Indisponibilité prolongée du gérant unique	V3	G2	Élevé

Analyse des risques et corrélation CVE



Synthèse : Cartographie → CVE ciblée → Outil de test (offensif)
risques

Risque modélisé	CVE associée	Test réalisable (offensif)	Détection / Mitigation (défensif)
Injection / RCE	CVE-2021-44228 (Log4Shell)	JMeter — payload JNDI <code>\${jndi:ldap://...}</code>	Wazuh + Suricata (signatures JNDI) ; patch Log4j ≥ 2.17
Path traversal / RCE web	CVE-2021-41773 (Apache 2.4.49)	Requête GET manipulée (<code>../</code>)	Suricata (signature traversée) ; patch $\geq 2.4.51$
RDP non sécurisé	CVE-2019-0708 (BlueKeep)	nmap + script NSE	Patch + NLA forcé + signature IDS Suricata
Bruteforce SSH	N/A (technique — MITRE T1110)	Hydra	Fail2Ban + MFA + clés SSH/RSA
Déni de service (DoS)	N/A (surcharge réseau/CPU)	JMeter (thread group max)	Prometheus (alerting CPU / latence) + rate-limiting pfSense

CVE-2021-44228 — Log4Shell. Exécution de code à distance via une recherche JNDI dans Apache Log4j 2 ($\leq 2.14.1$) : une chaîne journalisée comme `${jndi:ldap://...}` déclenche le chargement d'une classe distante. CVSS 10.0, décembre 2021.

CVE-2021-41773. Traversée de répertoire dans Apache HTTP Server 2.4.49 ; permet de lire des fichiers hors racine web, et d'aboutir à du RCE si `mod_cgi` est actif. (Le correctif 2.4.50 était incomplet → CVE-2021-42013.)

CVE-2019-0708 — BlueKeep. RCE pré-authentification dans les services Bureau à distance (RDP) de Windows 7 / Server 2008. *Wormable*. CVSS 9.8, mai 2019.

Limite assumée : Ces tests ont été conçus et documentés. Il n'y a pas exécution complète faute d'une mission réelle avec un client.

Catalogue des prestations (Packages)



Package	Contenu (Livrable technique)	Durée	Prix indicatif
Pack infrastructure PME	Active Directory + DNS + DHCP paramétrés	1 à 2 jours	≈ 1 200 €
Pack Sécurisation	Déploiement pfSense + configuration règles IDS	1 à 2 jours	≈ 1 500 €
Pack Supervision	Installation Prometheus + Dashboards Grafana	1 à 2 jours	≈ 1 300 €
Pack Audit technique	Analyse de vulnérabilités + rapport d'action	1 jour	≈ 800 €

Modèle économique assumé :

SAN-log_it privilégie les missions ponctuelles (Set-up / Audit). A ce stade de création (structure solo), il n'y a pas d'infogérance mensuelle continue ni de SLA contractuel sur la disponibilité (astreinte non soutenable).

Modèle de calcul du devis

$$\text{Prix} = (\text{Temps} \times \text{TJM}) \times \text{Coef_complexité} \times \text{Coef_risque} \times \text{Coef_valeur} + \text{Coûts_fixes}$$

Coefficient	Plage	Exemple d'impact
Complexité	1,0 à 2,0	AD simple (1,0) / Multi-site (1,6)
Risque	1,0 à 1,5	Intervention en prod critique (1,5)
Valeur	1,0 à 2,5	Mise en conformité NIS2 (2,0)

Hypothèses

- TJM : 500 €
- Durée : 2 jours
- Coefficients : complexité (1,3) × risque (1,2) × valeur (1,8)
- Cloud : 30 €/mois
- Référence SaaS : Microsoft Teams = 2 160 €/an

Modèle de calcul du devis

$$\text{Prix} = (\text{Temps} \times \text{TJM}) \times \text{Coef_complexité} \times \text{Coef_risque} \times \text{Coef_valeur} + \text{Coûts_fixes}$$

Ex : Jitsi-meet (20 utilisateurs)

$$\begin{aligned} & 2 \text{ jours} \times 500 \text{ € (TJM)} \times 1,3 \text{ (complexité)} \times 1,2 \text{ (risque)} \times 1,8 \text{ (valeur)} \\ & 1\,000 \text{ €} \times 1,3 = 1\,300 \text{ €} \times 1,2 = 1\,500 \text{ €} \times 1,8 = 2\,808 \text{ €} \end{aligned}$$

$$\begin{aligned} & = 2\,808 \text{ €} + (\text{Coûts Cloud}) = 360 \text{ €/an} = 3\,160 \text{ € puis } 360 \text{ €/an par an} \\ & = 3\,160 \text{ € vs Microsoft Teams} = 2\,160 \text{ €/an chaque année} \end{aligned}$$

ROI = Return On Investment

Formule :

$$ROI = \frac{\text{Gain} - \text{Coût}}{\text{Coût}}$$

- **Gain** = économies réalisées par rapport à une solution de référence

- **Coût** = investissement initial + coûts opérationnels

1. Application au cas : première année

$$ROI_{\text{année 1}} = \frac{2\,160 - 3\,168}{3\,168} = -31,8\%$$

ROI négatif (investissement initial)

2. À partir de l'année 2 : Gain annuel : 2 160 € Coût annuel Jitsi : 360 €

ROI positif

$$ROI_{\text{année 2+}} = \frac{2\,160 - 360}{360} = 500\%$$

3. Point d'équilibre (break-even) : 19 mois

$$\text{Seuil} = \frac{2\,808}{2\,160 - 360} \approx 1,56 \text{ ans}$$

Preuve de concept : Site-Web

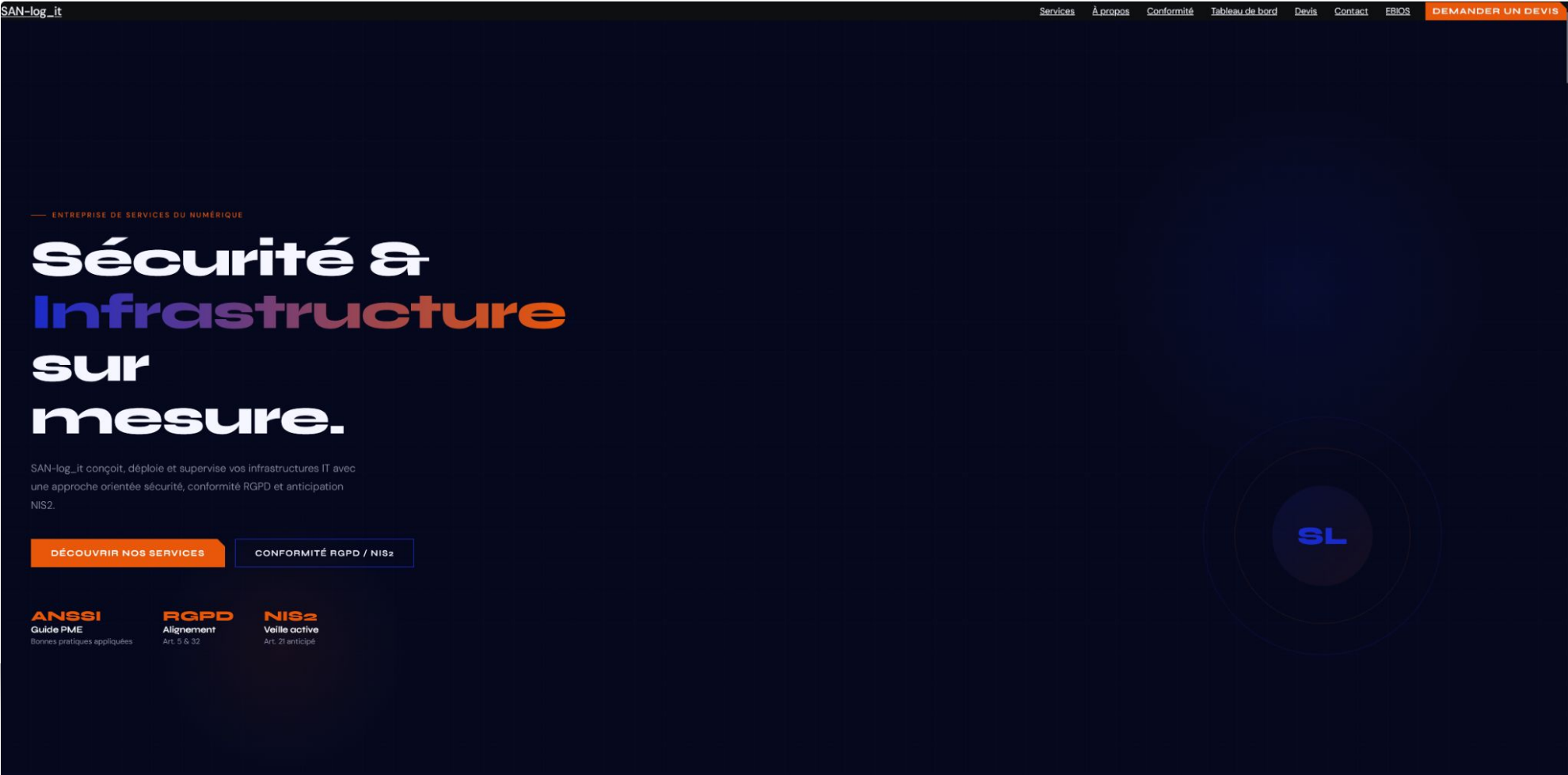
Composant	Technologie	Statut d'avancement
Hébergement	Docker natif dans Hostinger	Déployer
Framework Front	React + docker	Entièrement construit
Simulateur de devis	Formule mathématique intégrée	Fonctionnel
Pages vitrines	Accueil, Services, Offres, Devis, Contact	Toutes créées

https://github.com/001418-M1/SAN-log_it-Website

Ce que cela prouve techniquement :

- Capacité à déployer une application web professionnelle.
- Traduction d'un modèle économique abstrait en outil interactif.
- Création d'une vitrine crédible pour démarcher : <https://san-log-it.com/>

Preuve de concept : Site-Web <https://san-log-it.com/>



Preuve de concept : Simulateur <https://san-log-it.com/>



SAN-log_it

ServicesÀ proposEBIOSConformitéArchitectureDashboardDeviaContactFR

ESTIMER

Estimez votre prestation

Calculez une estimation indicative basée sur les paramètres techniques et métier de votre projet.

Cette estimation est fournie à titre indicatif et ne constitue pas une offre contractuelle.

Prix = Temps × TJM × Complexité × Risque × Valeur + Coûts fixes

Méthode d'estimation interne SAN-log_it.

Une étude détaillée pourra affiner cette estimation.

Type de mission

Infrastructure Active Directory

Durée estimée (jours — TJM 500 €)

2

Complexité technique

Moyenne (multi-services) (×1.3)

Niveau de risque

Moyen (exposition réseau) (×1.2)

Valeur métier

Standard (×1)

Coûts fixes mensuels (€ — cloud, hébergement)

0

CALCULER L'ESTIMATION

ESTIMATION

1560 €

Estimation non contractuelle — valable 30 jours

Détail du calcul

Base (2j × 500€)1000 €

+ Complexité1300 €

+ Risque1560 €

+ Valeur métier1560 €

Total estimé1560 €

Cette estimation est indicative. Pour obtenir une proposition commerciale détaillée ou contractualiser une prestation, utilisez le formulaire de contact.

Prix = Temps × TJM × Complexité × Risque × Valeur + Coûts fixes

Référence : estimation indicative basée sur les paramètres techniques déclarés.

Gestion des cookies

Nous utilisons des cookies nécessaires au fonctionnement du site ainsi que, avec votre accord, des cookies de mesure d'audience et de préférences.

ACCEPTERRefuser

Evaluation par rapport au RNCP 38117



Bloc	Intitulé	Commentaire SAN-Log_it	Auto-évaluation
Bloc 1	Piloter conception d'infrastructure sécurisée	Architecture documentée, analyse des besoins PME	Manque pilotage COMEX réel
Bloc 2	Déploiement sécurisé	Site web + simulateur + labo virtuel (captures)	Pas de prod réelle
Bloc 3	Stratégie de sécurisation	Cartographie risques + CVE + outils IDS/SIEM	Stratégie à approfondir
Bloc 4	Manager la performance	pilotage offre, KPI, roadmap recrutement	Pas d'équipe réelle
Bloc 5	Gestion nouveaux projets	CDC, MoSCoW, budget, faisabilité	Valable en l'état de l'art
Transversal	Anglais / Veille	Veille NIST/CIS (intégrée en annexe)	

Limites du mémoire



Limites

Pourquoi il est acceptable ?

Aucune mission client réelle

Stage non obligatoire. Candidatures infructueuses :
Pivot vers un mémoire spéculatif assumé et constructif.

Pas de validation sur le terrain

Compensée par les preuves de concept techniques réelles :
Développement du site, simulateur, laboratoire et expériences
personnelles antérieures (Tercium).

Architecture non déployée en production

Le laboratoire virtuel et la documentation technique démontrent
la maîtrise conceptuelle des briques (pfSense, Wazuh)

Pas de contrat d'infogérance, pas de SLA

Modèle économique volontairement limité : (et réaliste)
Aux missions ponctuelles pour une structure naissante.

Structure solo, pas d'équipe

Le mémoire projette clairement une évolution vers un statut de SASU :
Un recrutement à horizon 24 mois.

Évolutions possibles (Roadmap)



Court terme

(1 à 3 mois)

Formaliser la **PSSI** interne, nommer officiellement le **DPO**, et achever le déploiement de l'inventaire Wazuh sur le labo.

Moyen terme

(6 à 12 mois)

Audit externe de sécurité du SI (prestataire qualifié)
Mise en place d'un processus de qualification client (**KYC/KYB**)
Intégration du processus dans le site web (formulaire + contrôles)

KYC — Know Your Customer : Processus de vérification de l'identité d'une **personne physique**.

KYB — Know Your Business : Processus de vérification d'une **personne morale (entreprise)**.

Long terme

(24 à 36 mois)

Transformation légale en **SASU**, recrutement du premier technicien réseau, et amorce d'une démarche de certification **ISO 27001**.

Conclusion



SAN-Log_it est aujourd'hui une coquille légale sans client*, mais ce n'est pas seulement un cas d'école. C'est une intention entrepreneuriale sérieuse, modélisée techniquement et économiquement.

Le site web déployé sur Hostinger, le simulateur de devis, l'architecture documentée et les référentiels maîtrisés (**ANSSI, NIS2, CIS**) en sont les preuves. Il ne manque qu'une chose : un premier client.*

<https://san-log-it.com/>

Ma question pour vous : si vous étiez **DSI** d'une **PME**, quelle preuve supplémentaire attendiez-vous avant de me confier votre infrastructure ?"